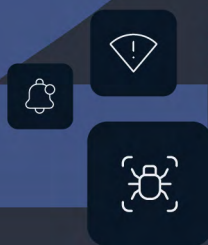




2026 Cyber Threat Landscape

REPORT



2026

Cyber
Threat
Landscape
REPORT

Introduction

The 2026 Cyber Threat Landscape Report comes at a time when security and risk analysts, operators, and agencies are both under immense pressure from being critically understaffed and an overwhelming volume of cyber events occurring every day. These events contribute to a rapidly expanding threat landscape that has been put into overdrive due to malicious use of AI that lowers the barrier to entry for unskilled actors and greatly increases the capabilities of advanced adversaries. Keeping up with the resulting chaos of today's cyber risk landscape is an ever-growing challenge.



This report looks at data from calendar year 2025. Using aggregated data from our industry-leading dataset and the expertise of leading cybersecurity experts, we are able to identify global trends and information. Dataminr ingests more than 43 terabytes of event, threat, and risk signals every day—an unmatched amount of data aggregation that feeds more than 55 proprietary LLMs and Agentic AI solutions as well as thousands of detection models.

These detections are further augmented and enriched with a proprietary knowledge graph of over 3 billion entities including unique IOCs and other objects. With Dataminr, customers gain the foresight they need to implement predictive and preemptive measures against possible threats, focus on threats with the most potential impact to their organization, and take the right action when every second counts.

Dataminr's detection models constantly identify, validate, and correlate risk signals from more than 1 million data sources. These sources include all the places that APTs, cybercrime groups, and lone wolf actors leave digital footprints, allowing Dataminr to detect activity across new and existing Telegram channels, data dump sites, breach forums, and any

developments across the deep and dark web with unmatched speed and precision. With the acquisition of ThreatConnect, Dataminr now also includes critical cyber incident loss data that enables sophisticated risk quantification metrics for unified threat intelligence, greatly enhancing the data conveyed in this report and the value it provides security teams worldwide.

In the report, you will find security trends and analysis relevant to your security operations organization—threat actor activity, external digital risks, frequently exploited vulnerabilities, and more. Moving beyond just the security operation centers (SOCs), it will also help readers understand business impact by quantifying the risk associated with vulnerabilities and malware.

The trends and data in this report not only represent the evolution of the threat landscape, but show how critical it is that SOCs are provided with the most accurate, relevant intelligence possible. When these teams are served up the latest intelligence about the most likely secondary and tertiary threats to their unique environment that could emerge, they gain precious minutes or hours needed to stay ahead of malicious actors.

Methodology

This report was written with both qualitative and quantitative approaches and relied primarily on data from Dataminr and ThreatConnect. In the event a data point was sourced from third parties, it was noted as such. The goal of the report is to provide cybersecurity teams with actionable insight into the cyber threat landscape as it has evolved over the past year so they can understand trends that would be helpful for the ongoing protection for their organization or agency.

Executive Summary

Dataminr's 2026 Cyber Threat Landscape Report aggregates global cyber intelligence to provide security leaders with a clear, quantified view of evolving risks—from the exponential rise in identity-centric attacks and high-impact “mega-losses” to the persistent threats posed by sophisticated, well-funded criminal and state-aligned groups.

Our analysis confirms that the window of time between targeting, initial access, and payload execution or data exfiltration has greatly diminished. This makes proactive, context-rich, and even predictive threat intelligence the non-negotiable requirement for organizational resilience in 2026.

Dominant Threat Actors and Tactics



- **Qilin:** Identified as the most active ransomware group of 2025, Qilin consolidated the market by offering high payouts and a stable platform for affiliates.
- **Cl0p:** This group utilized a “restraint and precision” strategy, focusing on encryption-less extortion to siphon terabytes of data while maintaining a low profile.
- **Scattered Lapsus\$ Hunters:** Demonstrated the vulnerability of the “human element” by using AI-enhanced social engineering to bypass technical security measures.
- **NoName05716:** Remained the most active pro-Russian hacktivist collective, primarily utilizing crowd-sourced DDoS attacks against critical infrastructure.

KEY STATISTICS FROM 2025

5,000+
threat actors tracked

225%
increase in monthly threat
actor alerts from 2024-2025

18,000+
alerts on ransomware activity

2,000,000+
domain impersonations

425,000+
instances of brand fraud

110,000+
alerts on doxxing or leaked
credential databases

Critical Vulnerabilities

The report emphasizes that technical severity based on the common vulnerability scoring system (CVSS) does not always equal business risk. While there were certainly high-scoring CVEs that also carried high remediation costs, such as CVE 2025-55182, it is always important to layer in factors such as likelihood of exploitation, potential business impact, and frequency of targeting. This allows organizations to move beyond the very binary approach of whether the CVSS score deems a vulnerability important enough for their teams to patch them.

Table of Contents



Introduction	2
Methodology	3
Executive Summary	4
Key statistics from 2025	4
Dominant Threat Actors and Tactics	4
Critical Vulnerabilities	4
Table of Contents	5
The Cyber Risk Landscape	6
Vulnerabilities	7
Digital Risk	10
Malware	14
Dual use tools	19
2025 Financial Impact Trends	22
The Rise of the “Mega-Loss”	23
Changing Tactics for the Attacker and Company	24
Threat Actor Activity	25
High Impact Groups	27
Group Summaries	28
Threat Actor Spotlight: jrintel	31
Operational Evolution	32
Most active actors by alert volume	34
Group Summaries	36
Conclusion	37
Appendix 1	39
About Dataminr & ThreatConnect	43



The Cyber Risk Landscape

It is impossible for humans alone to keep tabs on everything happening that presents cyber risk. Regardless of size, every organization and government agency has a complex infrastructure of assets to manage. For larger ecosystems, that number could reach millions of endpoints, software versions, and individuals across the globe that could be exposed to risk. All of these contribute to a complex web of assets and telemetry across an organization's infrastructure that need to be constantly evaluated, monitored, and protected.

Our View of the 2025 Cyber Risk Landscape

6.3M+

External threat alerts

(Ex: Malware, hacktivism, ransomware, APTs)

4.8M+

Vulnerability alerts

(Ex: Exploits, emerging vulnerabilities, disclosures.)

3.1M+

Digital risk alerts

(Ex: Domain impersonation, phishing, doxxing, data posture)

The numbers above represent why so many security and infrastructure teams feel overwhelmed. It's crucial to ensure only the most relevant alerts are being presented to the team. In situations like this, relevance can be tied to whether the risk is present in that organization's environment in the first place, what the organization's risk tolerance is, or what the potential impact is to the organization if the risk is left unresolved.

Vulnerability

Software vulnerabilities can be highly effective points of initial compromise and access for a threat actor—especially when they're discovered in widely-used solutions. Threat actors are constantly poking and prodding at software to find mistakes in code and bypass security measures. These risks could also present themselves at other points of an organization's supply chain if a deeply integrated technology is compromised, which unknowingly creates an access point to sensitive information.

Once the actor finds a way to exploit a weakness, their next step will depend on their end objectives. Many will try to sell the exploit code or tailored access by advertising it for sale on Dark Web forums or in Telegram channels. Some will take the riskier, but potentially more lucrative step, which is to use the exploit to access an organization's valuable data and either exfiltrate it, sell it or render it inaccessible as part of a ransomware attack.

Threat actors have long made practice of analyzing newly published vulnerabilities and newly released patches to understand where weak points may exist and reverse-engineer vulnerabilities to target systems that remain unpatched. This window of opportunity between when a vulnerability is disclosed, when the patch is released, and the vulnerable system is actually patched by system owners is frequently when the attacker has their best chance of success.

However, in 2025, the security landscape was defined by a "patch bypass epidemic," where critical fixes for major platforms were often immediately re-exploited due to incomplete root-cause remediation by the software vendor. The most prominent example was observed with a Microsoft SharePoint vulnerability, where attackers bypassed the initial July patches (CVE-2025-49706/49704) within days by using simple path traversal techniques, forcing the issuance of new CVEs (CVE-2025-53770/53771) for the same underlying flaws.

Microsoft Sharepoint RCE Vulnerabilities - “ToolShell”

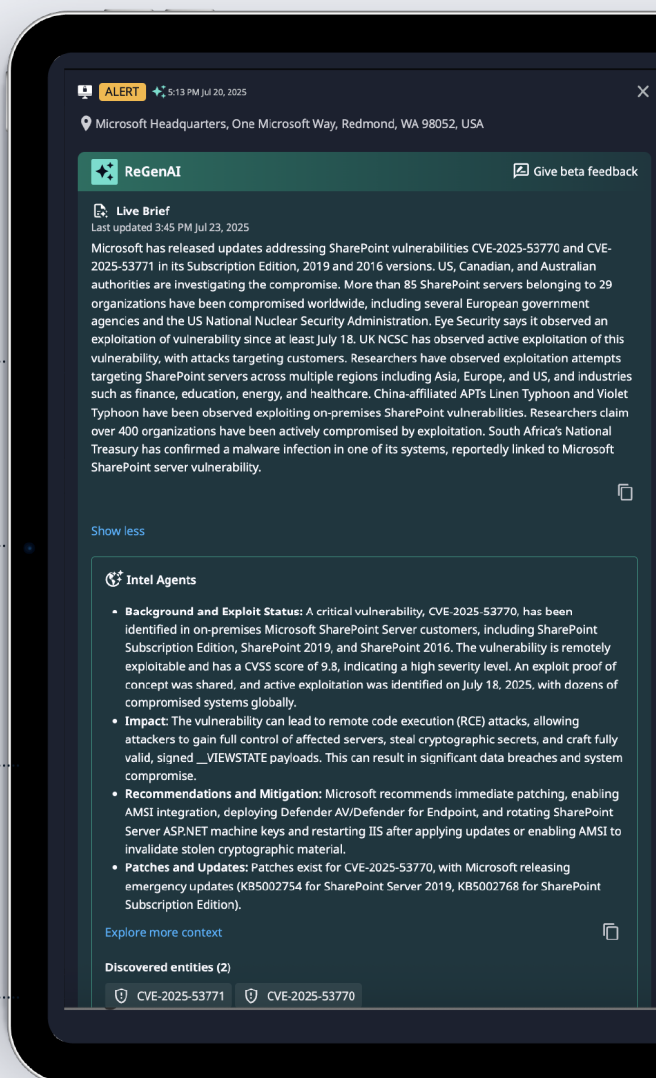
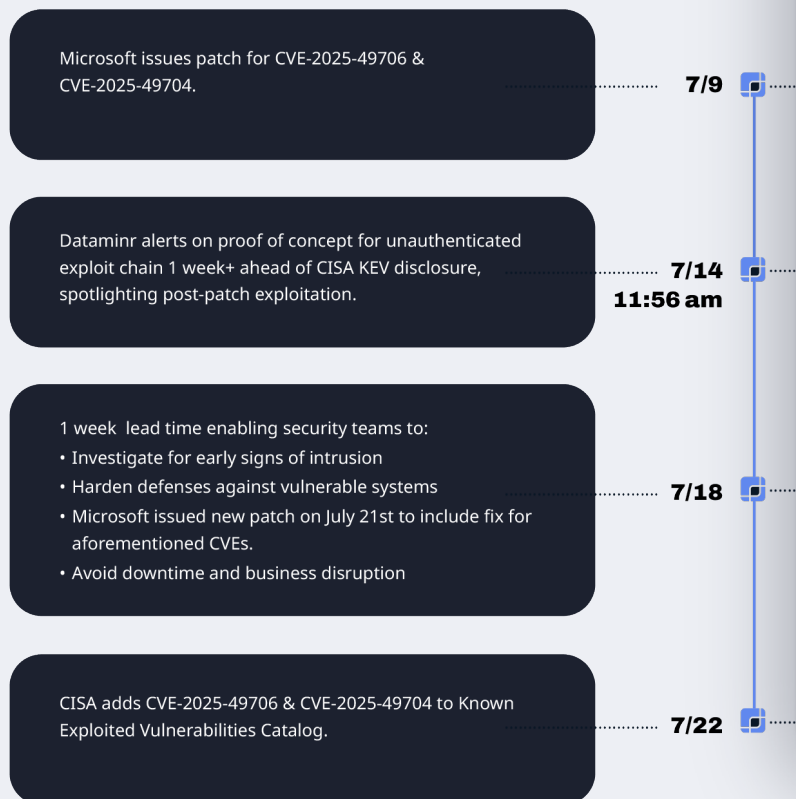


Figure 2. Vulnerability Reexploitation SharePoint Toolshell with Dataminr alerting enhanced by ReGenAI and Intel Agents.
Source: Dataminr

This pattern was repeated in Windows Server Update Services (WSUS) and SAP NetWeaver, where initial patches for critical vulnerabilities failed to account for all deserialization vectors, necessitating emergency out-of-band updates and secondary CVE assignments. Similarly, Grafana attempted to fix a vulnerability using client-side restrictions that were easily circumvented, rather than validating server-side input. Collectively, these four incidents highlighted a systemic failure in “variant analysis,” leaving organizations vulnerable even after applying vendor-supplied updates.

In addition to this challenge around re-exploitation, teams are monitoring and managing tens of thousands of new vulnerabilities every year. Many are rated “High” or “Critical” based on their Common Vulnerability Scoring System (CVSS) scores, which only take into account the technical impacts. While CVSS remains useful for understanding exploit mechanics, it provides limited insight into which vulnerabilities actually matter to a specific organization. Without additional context, security teams are left with an undifferentiated backlog of critical findings that obscures what truly warrants action, investment, and executive attention. A consistent observation is that severity does not always equal risk.

The CVE risk impact matrix reflects a more actionable approach: contextualizing CVEs with threat and risk intelligence tailored to the organization. By layering in the likelihood of being impacted, which takes into account factors such as frequency of the software being used in a specific industry, potential financial impact, and the degree of targeting or frequency, we move from generic vulnerability lists to a prioritized view of real risk.

CVE	CVSS SCORE	LIKELIHOOD OF BEING IMPACTED	POTENTIAL FINANCIAL IMPACT*	LIKELIHOOD OF BEING TARGETED	OVERALL RISK
CVE-2025-55182	10.0	VERY HIGH	\$\$\$\$\$	HIGH	CRITICAL
CVE-2024-1709	9.8	HIGH	\$\$\$\$	LOW	VERY HIGH
CVE-2025-53770	9.8	MODERATE	\$\$\$\$	HIGH	VERY HIGH
CVE-2025-11001	7.0	MODERATE	\$\$\$	HIGH	HIGH
CVE-2025-32433	10.0	VERY HIGH	\$\$\$	MODERATE	HIGH
CVE-2025-5777	9.4	VERY HIGH	\$\$\$	MODERATE	HIGH
CVE-2024-55591	9.6	VERY HIGH	\$\$	MODERATE	HIGH
CVE-2025-31324	9.8	LOW	\$\$	MODERATE	MODERATE
CVE-2024-4577	9.8	MODERATE	\$\$	LOW	MODERATE
CVE-2025-57955	6.5	MODERATE	\$	MODERATE	MODERATE
CVE-2023-6553	9.8	VERY HIGH	\$	MODERATE	LOW
CVE-2024-36401	9.8	HIGH	\$	LOW	LOW

Figure 3. For more in-depth information about each of these CVEs, mitigation steps, and the rationale behind the likelihood of being impacted and financial impact, view Appendix 1. Source: ThreatConnect Risk Quantifier

Adopting this approach enables security leaders to distinguish between vulnerabilities that are noisy but economically bounded and those that present systemic, enterprise-level exposure. More importantly, it represents the path forward for modern threat intelligence and vulnerability analysis—one that connects technical findings to business outcomes, aligns remediation with actual risk, and supports defensible, data-driven decision-making at both the operational and executive levels.

*Dollar signs represent modeled loss magnitude based on exploitability, estimated control effectiveness, and 20+ years of historical loss data.



Digital Risk

Aside from direct threats or vulnerabilities, organizations also need to be aware of external factors that could pose serious challenges in regards to third-party risks, brand reputation, and potential compliance violations. This is referred to as digital risk, which encompasses challenges such as domain impersonation, brand abuse in phishing campaigns, brand fraud, hacking services for sale, doxxing and leaked credentials, intellectual property and other data leaks.

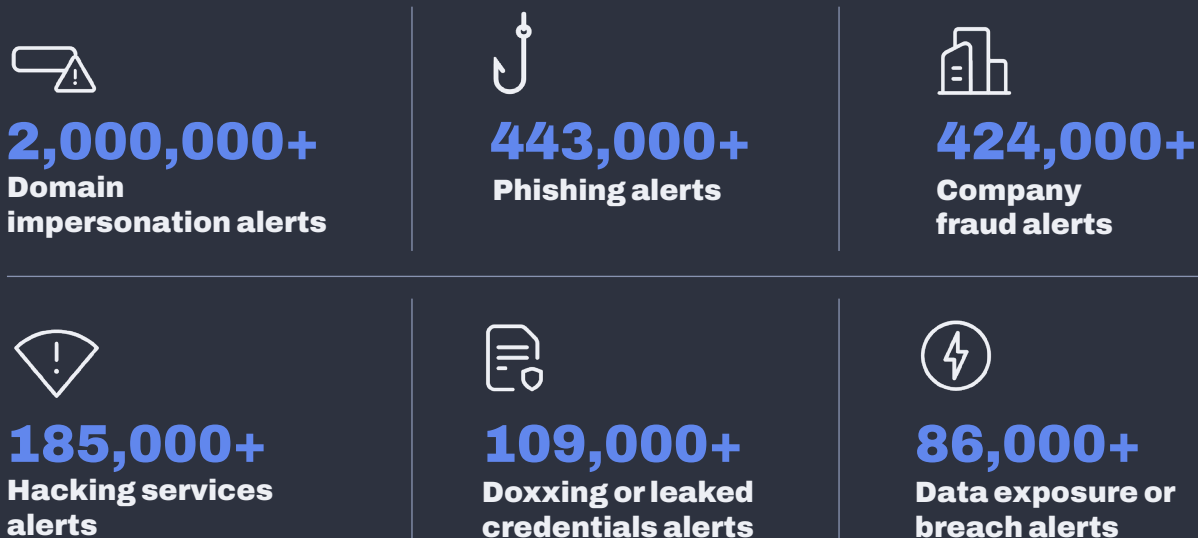


Figure 4. Data from the Dataminr Knowledge Graph (January 1, 2025 - December 31, 2025)

Events tied to these risk vectors typically occur outside of an organization's immediate purview. For example, if a third-party (or third-party software) is breached and an organization's customer or employee credentials are compromised, it might take days or weeks for their security team to become aware of the incident. In that time, the threat actor has a window of opportunity to quietly advance their attack on customers or enter their infrastructure and execute a further damaging attack.

If customer data is part of a breach, the organization could suddenly be held accountable for the financial implications—especially if there are any compliance violations involved. In some cases, threat actors will use a tactic called double extortion and threaten to notify the SEC or equivalent government body about a ransomware attack if the target organization doesn't pay up. For public sector organizations, that same scenario can lead to national security risks and help adversarial nation-states sow distrust in the government by claiming to have accessed the most personal data about citizens.



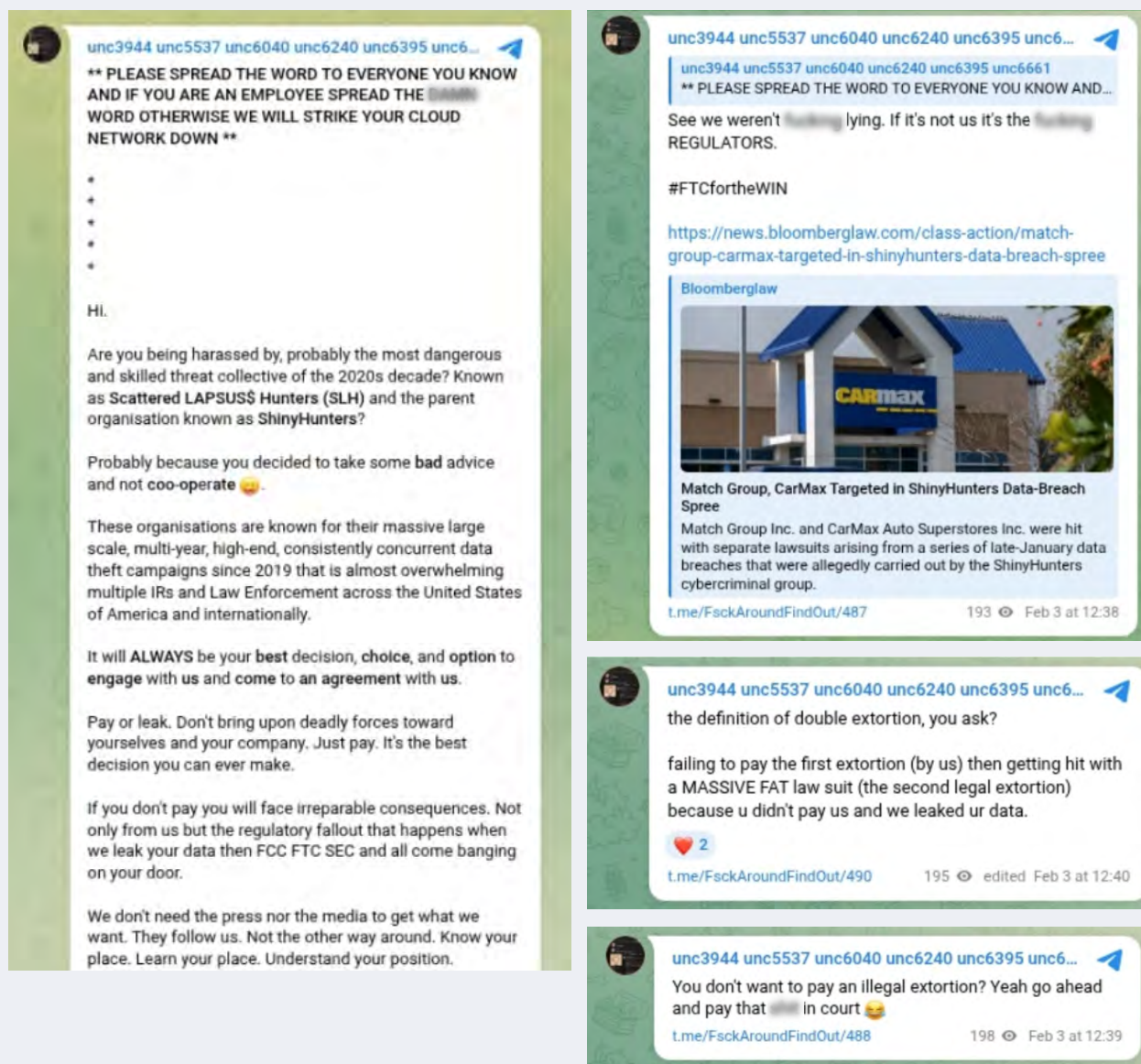


Figure 5. Threat actor group Scattered LAPSUS\$ Hunters (SLH) exhibits its use of double extortion in its Telegram channel.
Source: Dataminr

Domain impersonation, brand fraud, and phishing kits targeting an organization all threaten the integrity of an organization.

Depending on the actor's intentions, these can be used to target both customers and employees. While most sizable organizations operate under the assumption that there is likely an actor out there executing one of these attacks

and therefore have protections in place against the eventual compromise that could take place, there's a fine line between commodity phishing kits and an advanced, multi-pronged attack that fraudulently represents an organization.

Doxxing, data breaches, and leaked credentials represent a more imminent threat to an organization's systems, data, and employees. Data breaches are often the sources of follow-on activity like doxxing or leaked credentials, which makes it critical for an organization to know when a threat actor might be advertising their data for sale on a Dark Web forum or Telegram channel. With that knowledge, that organization can at least try to get ahead of eventual compromise by instituting proactive measures like company-wide password resets and additional monitoring for anomalous user behavior.

It's also important for an organization to know when a third-party vendor with access to sensitive data or systems is involved in a cyber attack or data breach. This can also extend to cloud infrastructure platforms that, if compromised, could unintentionally end up exposing customer instances. Being notified as early as possible about a possible breach elsewhere in the digital supply chain can be the difference between having a window of opportunity to remove any connection with the compromised platform and dealing with a significant data breach.

Third-party risk is just one of many reasons that resilience, or the ability to withstand a direct or third-party breach, is so important in the cloud. Many organizations align to a widely-known approach that takes into account three key principles - confidentiality, or preventing unauthorized data access; integrity, which ensures data is accurate and hasn't been tampered with; and availability, which guarantees that data is accessible even during disruptions.

PowerSchool Breach

Dataminr provided early warning of vulnerabilities by alerting on compromised PowerSchool credentials over six months before the breach occurred

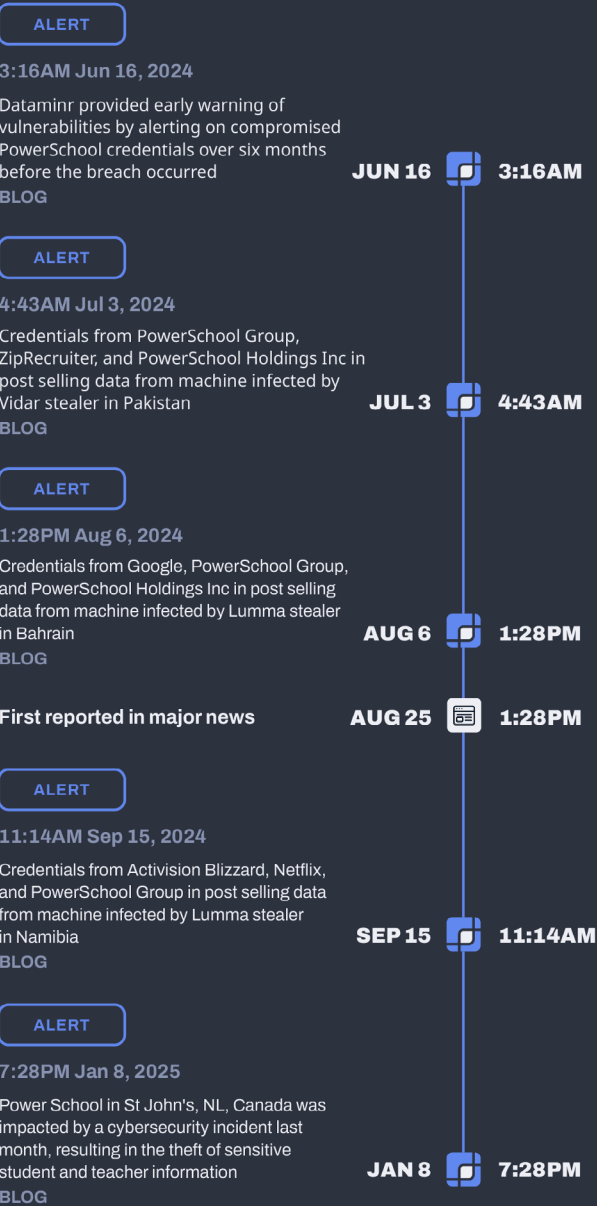


Figure 6. Timeline of key events pertaining to the PowerSchool breach as detected by Dataminr Source: Dataminr

Malware

SOC teams must be aware of chatter across the Dark Web, Telegram channels, and other places where adversaries discuss their next move or what tools they're finding most effective. They also need to know when independent researchers and other security teams come across novel malware or see a resurgence of existing malicious tools. This section provides an overview of the malware families with the most aggregate alerts from all sources in the Dataminr platform.

Beyond just knowing about the malware families, understanding how they're used, when activity associated with them is spiking, and what they target is crucial.

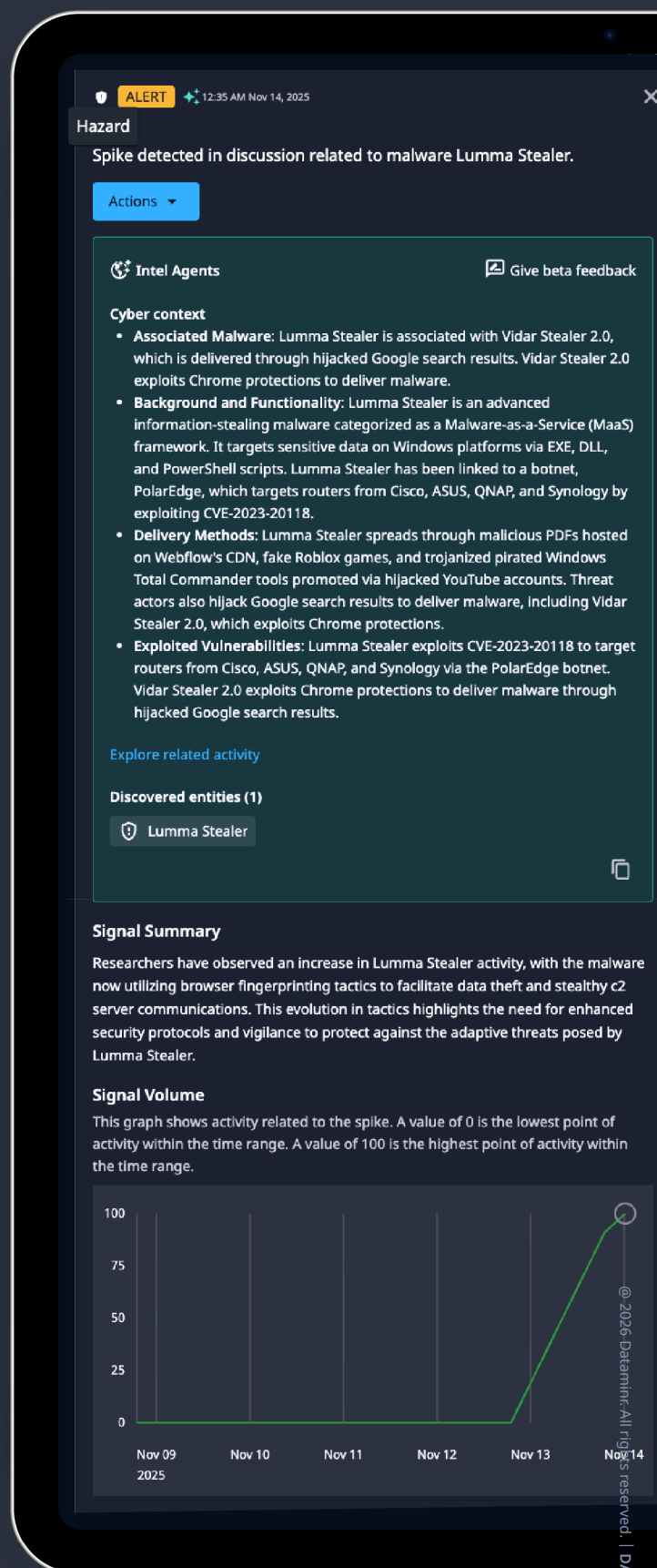


Figure 7. An alert showing that activity around Lumma Stealer is spiking. Source: Dataminr

For instance, knowing if a specific malware family is being deployed against a peer organization in a certain industry can be highly beneficial to informing proactive defensive posture. Threat actor groups frequently stick to successful methods, so if they manage to compromise several organizations within one industry using a particular type of malware, they are likely to repeat that attack chain.

MALWARE FAMILY	DESCRIPTION	BEHAVIOR
Mirai	Exploits weak default credentials and vulnerabilities in devices like routers and cameras to form massive botnets.	Can generate traffic bursts over 100 Gbps, targeting various sectors. Its proliferation and adaptation pose a growing risk to critical infrastructure.
Lumma Stealer	Sophisticated, MaaS infostealer distributed through Russian forums.	Uses anti-debugging and custom XOR obfuscation for evasion. Stolen data is exfiltrated via HTTP POST to a C2 server, delivered as EXE, DLL, or PowerShell.
Formbook	Also tracked as xloader (MaaS) infostealer, stealing browser credentials, keystrokes, clipboard content, screenshots, and web form data, and can download other files.	Employs sophisticated evasion techniques, including DLL search order hijacking, generating mutex names using SHA-1 hashes, and resolving API addresses with CRC32/RC4 encryption.

MALWARE FAMILY	DESCRIPTION	BEHAVIOR
Rhadamanthys	MaaS infostealer. Linked to Hidden Bee, its authors treat it as a long-term business, selling it for a monthly fee via Tor and Telegram.	The multi-stage infection uses loaders and employs new anti-analysis checks and a proprietary "XS" file format to evade PE parsers. Recent versions added browser fingerprinting. C2 configuration allows multiple servers and is downloaded as PNGs. Communication uses WebSocket with RC4-encrypted strings.
VoltRuptor	ICS & SCADA-specific malware strain reportedly developed by Russia-aligned hacking group Infrastructure Destruction Squad (IDS).	Designed for cross-platform operations. It features multi-protocol support, as well as persistence and anti-forensics capabilities.
Agent Tesla	Keylogger and RAT that captures clipboard data, screenshots, and audio/video.	Accepts nearly 40 commands for file management, command execution, process manipulation, and loading additional malware. The latest activity also utilizes .NET executables to decode and inject variants into processes.
NjRAT	RAT used for unauthorized system control. Facilitates malicious activities like keylogging, credential theft, webcam access, ransomware deployment, and system manipulation.	Collects data, disables security tools, manages files, and modifies Registry keys, typically spreading via phishing and drive-by downloads to grant command-line access.



Figure 8. Information that Dataminr provides about malware families as exemplified by NjRAT. Source: Dataminr

MALWARE FAMILY	DESCRIPTION	BEHAVIOR
Remcos	RAT that grants attackers full control over infected systems for data exfiltration and keystroke logging.	Evades detection using obfuscation, API hash values, Vectored Exception Handling, and process hollowing. Suspends legitimate processes (like a renamed "dllhost.exe"), injecting code, then resumes them.
ASyncRAT	Stealthy, polymorphic RAT targeting Windows. Capabilities include screen control, keystroke logging, file exfiltration, webcam capture, and remote desktop.	Achieves persistence by modifying the registry or creating new services, and evades detection using encrypted communications and anti-analysis techniques. Exfiltrates system data to a C2 server and can execute various commands, including downloading plugins, terminating processes, and updating itself.
Brickstorm	Sophisticated, cross-platform backdoor malware primarily used for long-term cyber espionage. Attributed to People's Republic of China (PRC) state-sponsored threat actors.	Uses advanced techniques to hide its command-and-control (C2) traffic, including DNS-over-HTTPS (DoH), nested TLS encryption, and WebSockets. This makes its malicious traffic look like legitimate web browsing. Includes a "self-watching" function that automatically restarts or reinstalls itself if it is killed. It also modifies system initialization scripts to ensure it survives reboots.

Figure 8. The most active malware families in 2025. Source: Dataminr Knowledge Graph

Dual Use Tools

In addition to outright malicious software, it's also important to be aware of tools that are legitimate, but can be leveraged by threat actors for malicious activity. This falls under the umbrella of a tactic known as "living off the land", which implies that the threat actor is able to infiltrate the organization and use existing tools, binaries, and scripts to execute malicious activities. This is not a novel tactic, and as such there is an open-source project known as Living Off The Land Binaries, Scripts, and Libraries (LOLBAS) meant to catalogue all binaries, scripts, and libraries that can be used in this tactic.

While these tools shouldn't be used without internal oversight, they're so widely used for legitimate reasons that they're rarely on block lists.

TOOL	PRIMARY LEGITIMATE USE	WHY THREAT ACTORS USE IT
Metasploit	The industry standard for penetration testing and exploit development.	Provides a massive library of ready-to-use exploits to break into systems.
Interactsh	Testing for "Out-of-Band" (OOB) vulnerabilities like SSRF or Blind SQLi.	Used to confirm if an exploit worked by pinging a server they control.
Sliver	An open-source adversary simulation (C2) framework.	A powerful, free alternative to expensive tools like Cobalt Strike.
GoPhish	An open-source phishing framework used by companies to train employees.	It makes setting up and tracking a mass phishing campaign very easy.
Burp Suite	The leading tool for web application security testing.	Used to intercept and modify web traffic to find or exploit web vulnerabilities.
Hak5 Cloud	Managing Hak5 hardware (like the Rubber Ducky or WiFi Pineapple).	Allows remote control of physical hardware used to compromise local networks.
Mythic	A modular, collaborative C2 framework for Red Team operations.	Its modular nature makes it very hard for defenders to create a single "fingerprint."

TOOL	PRIMARY LEGITIMATE USE	WHY THREAT ACTORS USE IT
Cobalt Strike	High-end commercial software for adversary simulation.	The “gold standard” for professional hacking. Attackers often use cracked versions.
XMRig	A high-performance, open-source Monero (cryptocurrency) miner.	The most abused on this list. It is frequently bundled into malware for "cryptojacking."
Havoc	A modern, open-source C2 framework focused on evasion.	Designed to bypass modern antivirus (AV) and EDR, making it perfect for stealth.

Figure 9. Dual-use tools that generated the most alerts in 2025. Source: Dataminr Knowledge Graph

To detect whether one of these tools is being used for legitimate or malicious purposes, security teams can look at both the endpoint and network traffic to flag anomalous behavior. At the endpoint level, teams can leverage their EDR solutions to look for anomalies such as sudden process changes or command lines, and scan memory for reflective DLLs or other code that shouldn't be there.

ALERT

2:34 PM Nov 15, 2025

×

San Francisco, CA

Proof of concept exploit posted for remote code execution vulnerability CVE-2025-6514 impacting Mcp Remote: "Metasploit module for CVE-2025-6514": Blog via GitHub Gist.

[View on GitHub Gist](#)

Actions

Intel Agents

Give beta feedback

Cyber context

- Vulnerability Background and Exploit Status:** A critical vulnerability, CVE-2025-6514, impacting the product mcp-remote, has been identified with a CVSS score of 9.6. This vulnerability is remotely exploitable and can lead to arbitrary OS command execution. Exploit code for CVE-2025-6514 is being sold on Twitter, and a proof-of-concept exploit has been shared.
- Impact and Severity:** The vulnerability has a CVSS score of 9.6, indicating a high severity level. It is remotely exploitable and can lead to arbitrary OS command execution.
- Compromised Environments and Affected Industry:** 437K developer environments have been compromised, primarily affecting the software development industry.
- Mitigation and Response:** JFrog's MCP Server has addressed security concerns with HTTPS.

[Explore related activity](#)

Discovered entities (1)

CVE-2025-6514

📄

Key Points

Vulnerability: CVE-2025-6514 | CVSS: 9.6

Vendor:

- mcp remote project

Impacted Product:

- mcp_remote

Malware: Metasploit

At the network detection level, anomalous communications can be the biggest indicator of malicious intent. Whether that's because a tool is directly pinging a known command-and-control (C2) server or suddenly tries to talk to a random domain, these are ways to know whether a threat actor might be behind the controls and trying to get in.

ALERT

2:53 PM Aug 25, 2025

×

Hanoi, Vietnam

Chinese cybercriminals exploited Telerik UI CVE-2019-18935 to hack 25 Vietnamese universities, using Godzilla and ByPassGodzilla web shells, Cobalt Strike, and VShell: Blog via Newspot Ru.

[View on Newspot Ru](#)

According to Newspot Ru

Actions

Intel Agents

Give beta feedback

- Threat Actor Background:** Threat actors Cobalt Group, Earth Lamia, UAT-6382, H2Miner botnet, and Play ransomware gang have been identified. CYFIRMA, a North Korean APT group sponsored by North Korea, has also been involved. Cobalt Group is financially motivated and unsponsored, while H2Miner botnet exploits vulnerabilities to mine Monero.
- Threat Actor Motivation:** Threat actors are financially motivated, with Cobalt Group seeking financial gain and H2Miner botnet focused on mining Monero. The Play ransomware gang is focused on ransom, having compromised 900 organizations.
- Malware Functionality and Features:** Malware such as Cobalt Strike, MimiKatz, JuicyPotato, and Schtasks have been identified. Cobalt Strike is a commercial penetration testing tool affecting Windows, particularly its Beacon payload. MimiKatz is an open-source application for viewing and saving authentication credentials, compatible with the current release of Windows. JuicyPotato targets Windows Service Accounts, and Schtasks is a Windows utility.
- Exploited Vulnerabilities:** Threat actors have exploited vulnerabilities including CVE-2025-0994, CVE-2025-31324, CVE-2024-9047, CVE-2023-46604, CVE-2024-57726, CVE-2024-57727, and CVE-2024-57728. These vulnerabilities have been exploited to breach organizations in various regions.
- Recent Activities and Victims:** Threat actors have exploited vulnerabilities in Telerik UI, SharePoint, SAP NetWeaver, and Cityworks to breach organizations in Vietnam, Brazil, India, and Southeast Asia. The DragonForce ransomware group has compromised over 120 victims, and the H2Miner botnet has targeted Linux, Windows, and containers to mine Monero.
- Historical Focus:** The H2Miner botnet has historically focused on mining Monero, while the Play ransomware gang has focused on ransom. Cobalt Group has been financially motivated and unsponsored.

[Explore related activity](#)

Figure 10. Dataminr alerts on threats pertaining to popular dual-use tools. Source: Dataminr



2025 Financial Impact Trends

From a financial loss perspective, 2025 marked a clear shift from “frequent but contained” cyber losses toward fewer events with materially larger financial and mission impact. While ransomware volumes stabilized, single-incident losses increased, driven by multi-vector attacks that combined credential theft, data exfiltration, operational disruption, and regulatory exposure into one event.

The most consequential losses increasingly stemmed from identity compromise, third-party concentration risk, and exploitation of trusted business processes, rather than purely technical exploits—pushing cyber risk firmly into the category of balance-sheet and earnings volatility, not just security operations cost.

The Rise of the “Mega-Loss”

The Normalized Severity Distribution confirms that 2025 is the year of the “tail event.”

- **Loss density shift:** The 2025 KDE (Kernel Density Estimation) shows a distinct migration of loss probability toward the right. Large-scale clusters have appeared at the \$100M and \$1B+ levels, which were virtually absent in 2024.
- **Ransomware tail risk:** For ransomware, the 2025 probability curve is significantly flatter and longer, indicating that multi-billion dollar losses are no longer black swan events but are increasing in likelihood.

The Normalized Severity Distribution - Trends (2024 vs 2025)

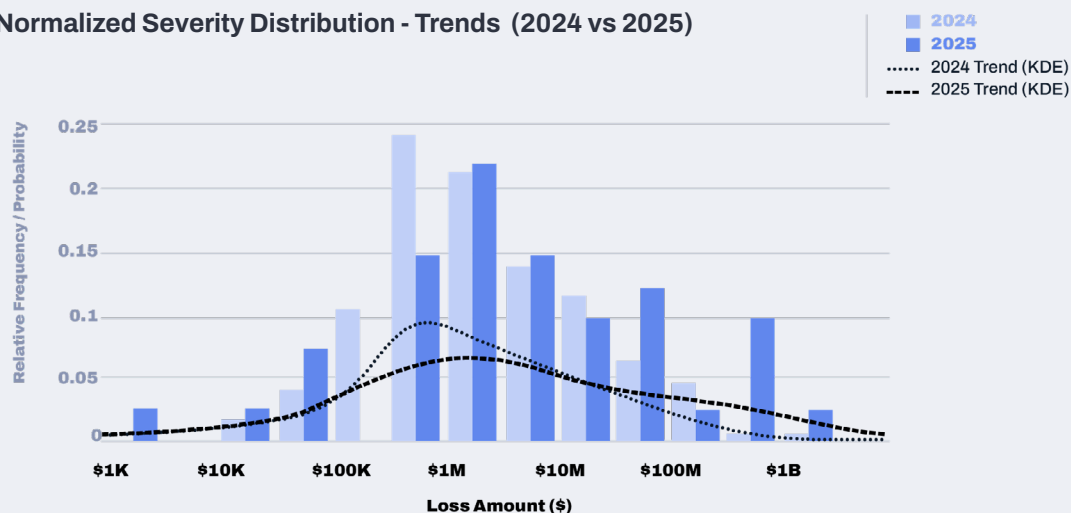


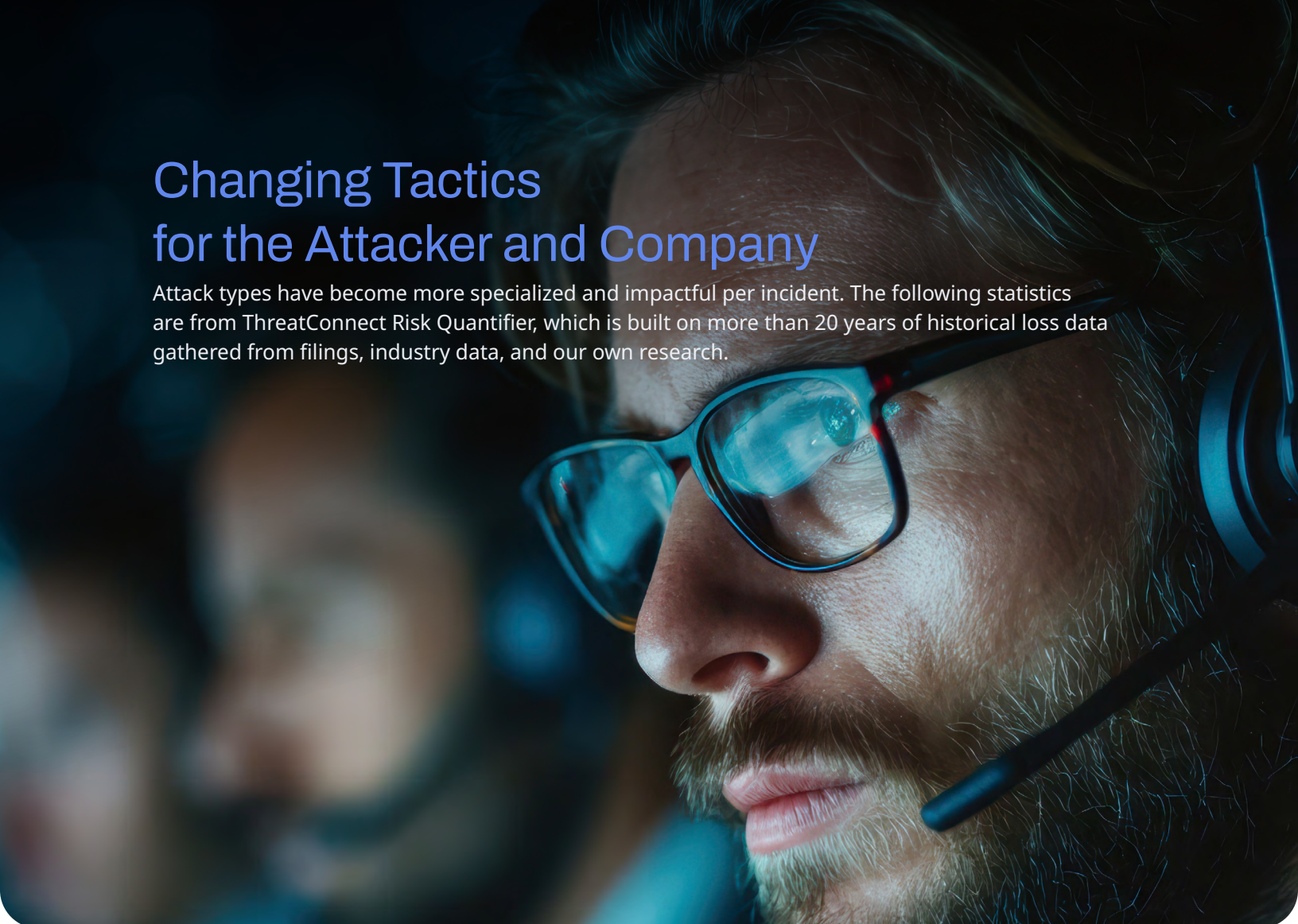
Figure 11. The Normalized Severity Distribution. Source: ThreatConnect Risk Quantifier

This chart illustrates a rightward shift in loss severity from 2024 to 2025. While both years show low probability at the extremes—small losses and catastrophic (\$1B+) events—the median loss was higher and more frequent in 2024, reflecting a greater concentration of moderate, repeatable incidents. In contrast, 2025 exhibits a thinner middle but a heavier tail, indicating fewer typical losses yet a meaningfully higher probability of very large, outlier-driven cyber loss events, consistent with increased systemic and concentration risk.

Methodology (Loss Severity Distribution Comparison)

This chart is derived from a normalized loss-severity analysis comparing cyber events observed in 2024 and 2025. For each year, individual cyber loss events were modeled using total financial impact per incident, inclusive of direct response costs, business interruption, data loss, legal/regulatory exposure, and downstream recovery effects. Loss values were then transformed into a probability density function and normalized to enable shape-based comparison across years, independent of absolute event counts.

The x-axis represents modeled loss magnitude on a continuous scale, while the y-axis reflects relative frequency (probability). Normalization ensures differences between 2024 and 2025 highlight distributional shifts—particularly changes in median concentration and tail risk—rather than differences in reporting volume or sample size.



Changing Tactics for the Attacker and Company

Attack types have become more specialized and impactful per incident. The following statistics are from ThreatConnect Risk Quantifier, which is built on more than 20 years of historical loss data gathered from filings, industry data, and our own research.

Identity is the new perimeter:

Nearly one in three (30%) cyber intrusions now involve the use of valid credentials—attackers are “logging in” rather than “breaking in.” This is fueled by an **84% increase** in infostealer malware delivered through phishing.

Phishing resilience:

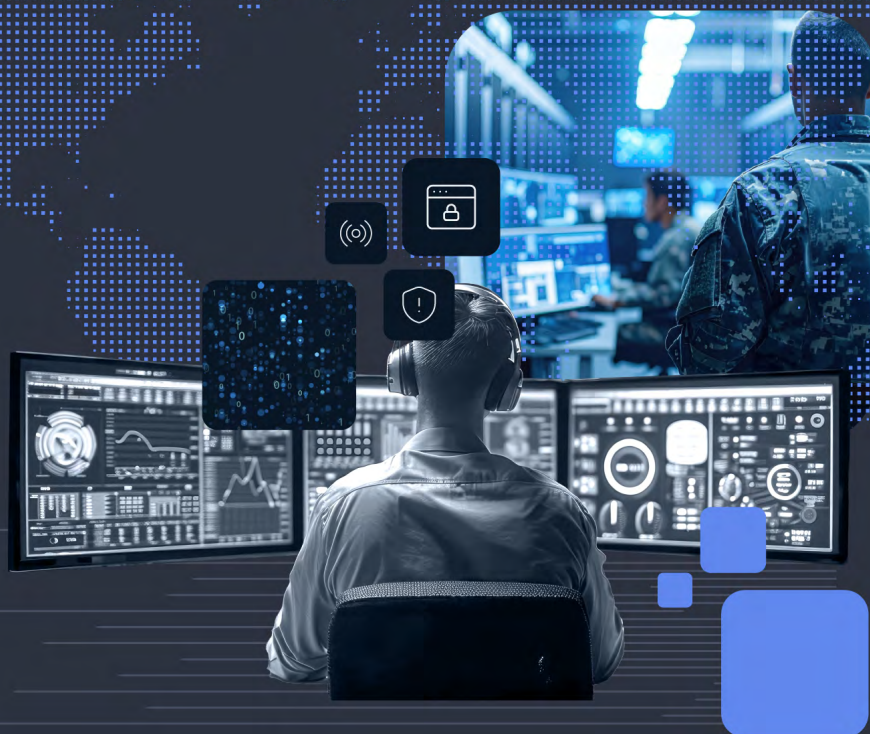
Phishing remains the dominant intrusion vector in 60% of cases. By early 2025, AI-supported phishing campaigns represented over **80%** of observed social engineering activity worldwide.

Payment refusal trends:

Despite higher severity, organizations are pushing back; **63%** of organizations opted not to pay ransoms in 2025, up from 59% in the prior year.

Supply Chain Gravity:

One in four modern breaches now exploits a third-party vulnerability (CVE), escalating the risk magnitude by 20% compared to direct internal attacks. This “Vendor Pivot” is characterized by extreme velocity; **96%** of these vulnerabilities are weaponized within the same calendar year of disclosure, frequently bypassing internal detection and resulting in twice the data impact per incident.



Threat Actor Activity

Over the course of 2025, threat actor activity consistently increased and represents a significant jump from 2024. In fact, there was a sizable 225% increase in average monthly alerts (1,490/month to 4,840/month), with the busiest month in 2024 not even reaching the quietest month in 2025. These statistics are derived from the Dataminr Knowledge Graph, which tracks all events and leverages AI to tag them with the appropriate threat actors.



Threat Actor Activity: 2024 vs 2025



Figure 12. Threat Actor Activity: 2024 vs 2025. Source: Dataminr Knowledge Graph

For any team tasked with protecting against cyber threats, they face the challenge that the dwell time between initial breach and catastrophic data theft has effectively been reduced to zero, making the earliest possible signaling of a campaign a critical requirement for survival. Because these modern adversaries often use dual-use administrative tools to “live off the land” once inside, traditional signature-based detection is often ineffective.

While threat actors often do their best to go undetected, there are some tactics they use that can serve as early warnings of an attack. These early warnings could include chatter across Dark Web forums, trying to recruit insiders, an influx of social engineering attempts, or increasing probes on a certain vulnerability. This was proven in the case of CVE-2025-6446, a zero-day in Fortinet’s web application firewall (WAF) solution that could grant attackers full admin-level privileges to applications behind vulnerable versions of the firewall. The timeline below illustrates the 38 days between initial detection and when the vulnerability was published in the Known Exploitable Vulnerabilities (KEV) catalog.

Dataminr's First Detection

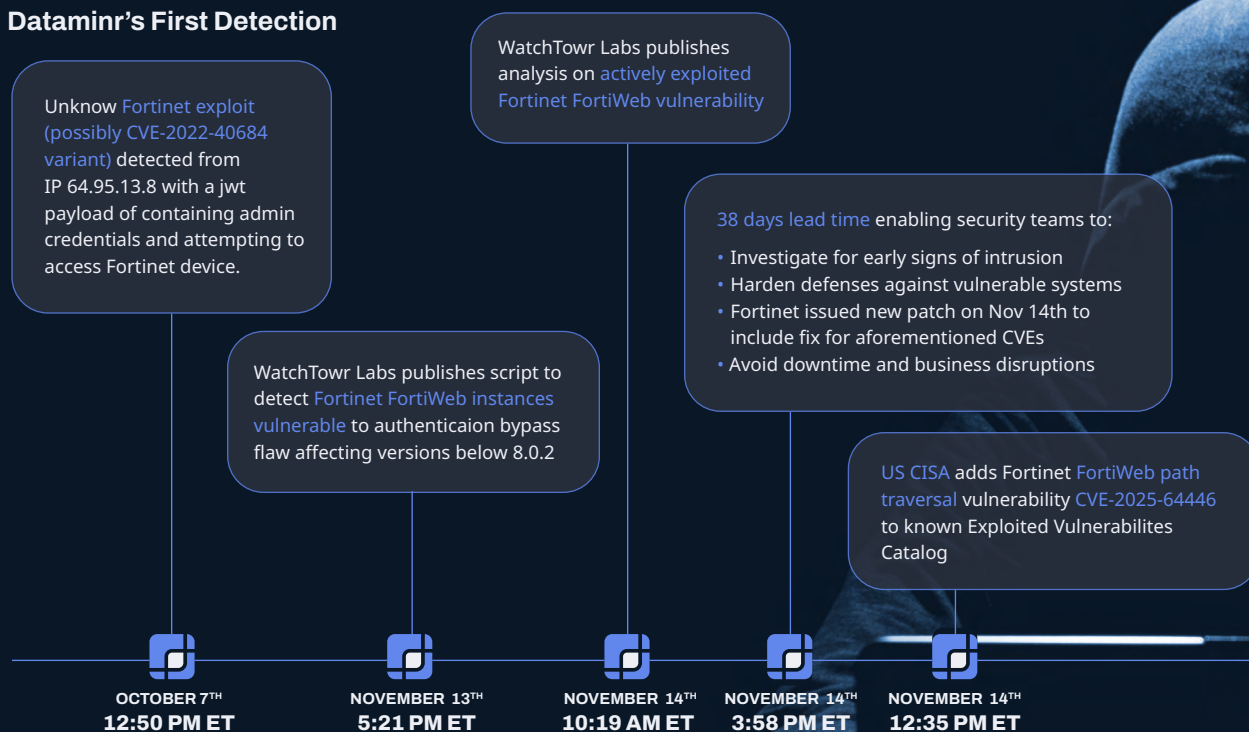


Figure 13. Timeline of key events pertaining to CVE-2025-64446 as detected by Dataminr Source: Dataminr

High Impact Groups

Advanced collectives moved away from traditional software exploits in favor of “identity-centric” warfare, where the human element became the primary entry point through AI-enhanced social engineering. The group that most prominently executed the identity-centric playbook was Scattered Lapsus\$ Hunters, or SLH, an alliance of three sub-groups of the cybercrime collective known as The Com. Not only has SLH arguably perfected the use of AI-enhanced social engineering by leveraging voice phishing (vishing) and other tactics to compromise entire organizations, but they also managed to compromise SaaS solutions so deeply integrated into other systems that the actors could compromise dozens of organizations at once.

Simultaneously, the focus shifted from simple system disruption to massive, “encryption-less” data exfiltration. By weaponizing zero-

day vulnerabilities in common enterprise file transfer and resource planning platforms, these actors were able to compromise handfuls of organizations in a short window, holding corporate reputations and proprietary intellectual property hostage rather than merely locking down operational files.

The graph below represents the volume of critical severity alerts in 2024 and 2025. These alerts are classified as Flash or Global Urgent by Dataminr and are critical enough to warrant the attention of SOC teams globally because of the attack’s scale and severity. As was the case in Figure 11 comparing 2024 to 2025, there is a significant increase year-over-year, especially in the second half of 2025, driven by a sharp increase in activity from actors CIOp, SLH/Scattered Spider, Qilin, Everest, and Jrintel.

High Criticality Threat Actor Activity:
2024 vs 2025

■ 2024
■ 2025

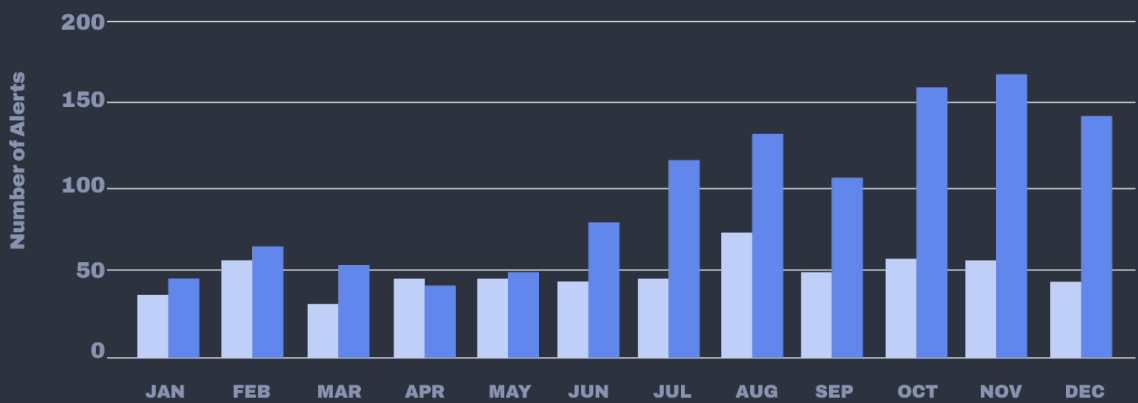
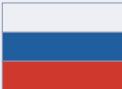


Figure 14. High Criticality Threat Actor Activity: 2025 vs 2025. Source: Dataminr Knowledge Graph

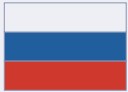
Regardless of whether an organization is directly impacted or not by that particular incident, these alerts indicate that the threat actor is actively targeting victims and could be on the lookout for vulnerable organizations.

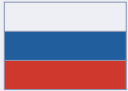
The following are overviews of the most active threat actor groups that drove these high-impact events—each of which drove between 10 and 40 high-criticality alerts during 2025. Hundreds of additional groups made up the remaining events.

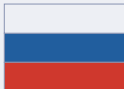
Group Summaries

CI0p Russia CI0p's 2025 activity highlights a "restraint and precision" strategy. By avoiding the noise of system encryption, they maintain a lower profile while dwell-time increases, allowing them to siphon terabytes of data before an intrusion is even detected by the victim.		
TARGETED INDUSTRIES	TACTICS	
• Manufacturing & Logistics • Consumer Goods & Services • Technology • Education • Critical Infrastructure	• Encryption-less extortion via data theft • Zero-day exploitation • Automation • Pressure tactics via third-party accounts	

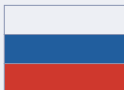
Scattered Lapsus\$ Hunters United States & United Kingdom The 2025 SLH proved that technical “un-hackability” is irrelevant if the human at the help desk can be manipulated. Their success forced a global shift toward phishing-resistant MFA (FIDO2) as the only viable defense against their social engineering prowess.		
TARGETED INDUSTRIES	TACTICS	
• Aviation • Retail & Fashion • Financial Services • Insurance • SaaS Ecosystems	• AI-Enhanced vishing • Social engineering • OAuth & API hijacking • Insider recruitment	

Infrastructure Destruction Squad (IDS) / Dark Engine Russia They emerged in 2025 as a highly aggressive and technically capable “hacktivist”. Despite an independent, ideological persona, their sophisticated targeting in 2025 suggests close alignment with state-level strategic interests.		
TARGETED INDUSTRIES	TACTICS	
• Energy & Utilities • Smart infrastructure • Agriculture, water treatment, and food processing facilities • Government	• VoltRuptor malware • Human-machine interface (HMI) hijacking • Anti-forensics	

Qilin Russia By providing the most stable platform and high payouts, they effectively consolidated the ransomware market, turning disparate cybercriminal cells into a unified, high-tempo threat.		
TARGETED INDUSTRIES	TACTICS	
• Manufacturing & Industrial • Healthcare & Life Sciences • Government • SaaS & Managed Service Providers (MSPs)	• Supply chain compromise • Double-extortion ransomware • Vulnerability weaponization	

Everest Likely Russia By acting as both the intruder and the broker, Everest has become a “force multiplier” for the entire cybercrime economy, making them a primary threat to enterprise-level supply chains.		
TARGETED INDUSTRIES	TACTICS	
• Aviation & Aerospace • National Critical infrastructure • Corporate HR & financials	• Insider recruitment • SaaS Supply chain • Data extortion • Access brokering	

JR Intel Europe JR Intel represents the “Data Brokerage” evolution of cybercrime. In 2025, their activity proved that the value of stolen intellectual property (e.g. source code and schematics) often exceeds the value of a ransomware payout, as this data can be sold repeatedly to state actors or industrial competitors.		
TARGETED INDUSTRIES	TACTICS	
• Big Tech & Hardware • Critical Infrastructure • Telecommunications • Defense & Government • Global E-commerce	• API & third-party service exploitation • Credential harvesting via info stealers • Silent data exfiltration • Public data auction & leaks	

Inc Ransom Likely Russia Inc Ransom's success in 2025 stems from their “business-like” reliability. Unlike more volatile groups, they have gained a reputation for providing working decryptors upon payment and honoring “no-leak” agreements, which ironically makes victims more likely to pay.		
TARGETED INDUSTRIES	TACTICS	
• Healthcare • Education • Government	• Double-extortion ransomware • Advanced tool mimicry • Spear-phishing • Vulnerability exploitation	

Threat Actor Spotlight: jrintel

jrintel (also known as JR Intel, hubz, or hubzXjrintel) is a high-profile, financially motivated mercenary information broker that emerged in August 2025. Unlike state-sponsored groups, jrintel operates as an opportunistic independent broker, specializing in trafficking sensitive military, intelligence, and government data from a wide range of geopolitical adversaries, including the U.S., China, Russia, Israel, and NATO.

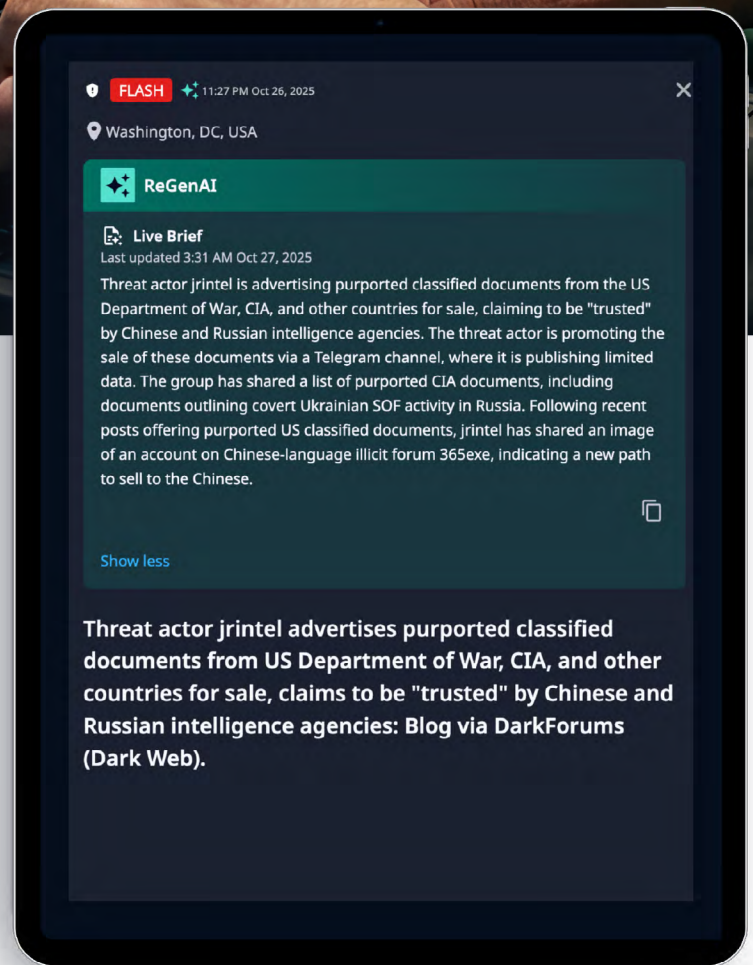


Figure 15. Dataminr alert of jrintel claim from DarkForums.
Source: Dataminr



Operational Evolution

The actor's capabilities have evolved rapidly through three distinct phases:

PHASE 1:

Military Technical Espionage (Aug–Oct 2025): Focused on high-tech military hardware to establish credibility. Key leaks included schematics for the U.S. Navy Arleigh Burke-class destroyer, SpaceX Raptor engines, and the Sukhoi S-70 Okhotnik-B drone.

PHASE 2:

Broad Intelligence & PII Theft (Nov–Dec 2025): Expanded into bulk personal identifiable information (PII) and civilian databases. Notable activity included leaking data on CIA, MI5, and Mossad agents, and a database purportedly covering all UAE citizens.

Recruited social engineering operators to target cryptocurrency investors, with observed TTPs and chatter suggesting a connection between jrintel and the predominantly English-language cybercrime ecosystem known as “The Com.”

It is also important to note that jrintel actively encourages users on Telegram to inflate their reputation on illicit forums, as such this is not a reliable indicator of credibility.

PHASE 3:

Hybrid Operations & Services (Dec 2025–Jan 2026): Transitioned into “Espionage-as-a-Service,” merging digital theft with physical-world activities. This includes recruiting for physical reconnaissance in Mali and seeking U.S. government insiders with access to confidential military blueprints.



Figure 16. Image of post of DarkForums from Dataminr alert of jrintel publishing purported passports of China Foreign Affairs Ministry officials.
Source: Dataminr

TACTIC	DESCRIPTION
Supply Chain Targeting	Exploits third-party vendors and defense contractors (e.g., Raytheon, Thales) to bypass direct government security.
"Proof of Life" Leaks	Releases 2–5 authentic-appearing "teaser" documents to verify access before soliciting sales reaching up to \$150,000 USD.
Cross-Platform Hype	Uses forums like DarkForums and BreachStars to build reputation, while conducting sales via encrypted platforms like Telegram and Session.
Insider Recruitment	Actively posts job listings for "pentesters" and government insiders to facilitate ongoing data exfiltration.
 jrintel User Posts: 51 Topics: 44 Leaks: 43 Reputation: 11 USA INSIDERS: Looking for someone with easy access to confidential documents e.g. political or future planning Also interested for people that have access to certain military blueprints. You will have to provide me proof of you geneva conventions identity card and log into NIPRNET on video Unless you dont work with the DOD then your identity card is fine.	
	Figure 17. Image from Dataminr alert of jrintel post of Breachstars seeking to recruit U.S. government and military personnel with clearance. Source: Dataminr



Most Active Actors by Alert Volume

This section dives into the most active actors by alert volume over the course of the year. Unsurprisingly, these actors are more focused on less sophisticated and highly repeatable attacks like DDoS. For an infrastructure security team, DDoS attacks can be massive challenges—especially if they’re being used to distract the team away from a larger attack, take down core operations, or have knock-on effects on customers.

It’s interesting to observe that, while most actors rely on botnets to gain the critical mass needed to execute a DDoS attack, NoName05716 crowd-sources its critical mass and gamifies the process with its followers.

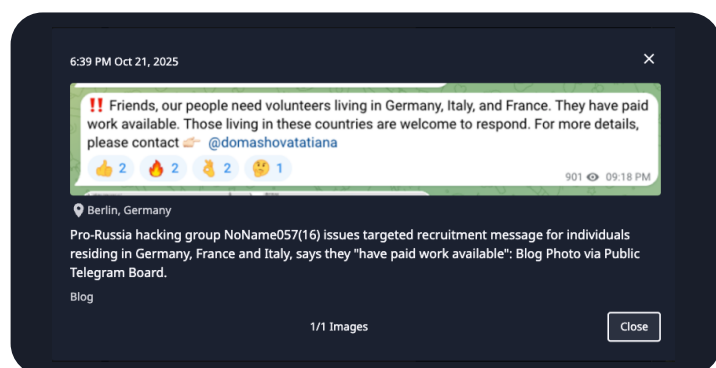


Figure 17. A screenshot from Telegram where NoName05716 is trying to recruit local actors. Source: Dataminr

This is all part of the DDoSia Project, which the group launched in 2022. They subsequently started awarding participants for successful attacks with cryptocurrency by launching dCoin. As shown in figure 18 below, they also use this to reward participants for recruiting other members.



Figure 19. Additional alerts regarding NoName05716's DDoSia Project
Source: Dataminr

Group Summaries

NoName05716

The most active pro-Russian hacktivist collective, despite significant international law enforcement pressure.

TARGETED INDUSTRIES

- Critical infrastructure
- State & city-level government

TACTICS

- Crowd-sourced DDoS
- Gamification of followers

Hezi Rash (meaning “Black Force”)

A relatively new but hyper-aggressive Kurdish nationalist group.

TARGETED INDUSTRIES

- Government
- News outlets
- Streaming platforms
- Financial services

TACTICS

- DDoS
- Botnets
- Residential IP Proxies

Keymous+

The name represents the 2025 trend of “mercenary hacktivism”—groups that use ideological slogans to build a brand for their commercial DDoS services.

TARGETED INDUSTRIES

- Government
- Financial services
- Telecoms

TACTICS

- DDoS

RomCom

Also tracked as Storm-0978, it is one of the most sophisticated “hybrid” actors, seamlessly switching between state-aligned espionage and high-value financial theft.

TARGETED INDUSTRIES

- Financial services
- Defense
- Manufacturing
- Energy
- Government

TACTICS

- Zero-day exploitation
- Malware upload via portal abuse
- Spearphishing
- Backdoors



Conclusion

The findings in this report demonstrate two critical, undeniable takeaways for any enterprise or government security team: the power of interconnected intelligence and the need for purpose-built AI to handle the chaos of today's cyber threat landscape.

A siloed view of cyber risk and threats is no longer viable, and organizations must move beyond generic scoring and analysis. Now, to get the full picture, it's important to look at how a few key factors intersect and overlap.

- **Holistic Visibility:** Merging vulnerability data with real-time threat actor activity and external digital risks, such as domain impersonation and credential leaks, provides a complete view of an organization's attack surface.
- **Contextual prioritization:** The report proves that technical severity (CVSS) does not always equal business risk. True intelligence requires layering in the likelihood of exploitation and frequency of targeting given an organization's unique infrastructure. This also helps understand potential financial impact.
- **Operational resilience:** By connecting technical findings to business outcomes, organizations can transition from a reactive "undifferentiated backlog" to data-driven decision-making that protects the balance sheet from "mega-losses."

When it comes to AI, the data in this report shows that the threat landscape has reached a level of complexity and speed where human-only teams can no longer manage the chaos on their own.

- **Collapsing time to exfiltration:** With the window of time between initial breach and data theft getting shorter every year, security teams require the earliest possible signaling of a threat actor activity to survive.
- **Combatting AI with AI:** Advanced adversaries are already using AI to lower the barrier to entry for unskilled actors and enhance the social engineering capabilities of experts. Only platforms built with proprietary LLMs and Agentic AI can ingest the 43+ terabytes of data daily required to identify these signals.
- **Bridging the talent gap:** As agencies and operators remain critically understaffed, specialized AI platforms act as a force multiplier—automating the correlation of signals from millions of sources to provide the foresight needed to take action when every second counts.

These two strategic cornerstones are not mutually exclusive. By acknowledging the opportunity that AI enables to embrace the power of interconnected intelligence, teams can put themselves in an advantageous position to take proactive action against emerging cyber threats in a way never been possible before.

Dataminr, now together with ThreatConnect, remains dedicated to its mission of delivering the most relevant and accurate AI-powered real-time event, threat & risk intelligence to its customers. Combining best-in-class intelligence with more than a decade of experience building a platform with AI at its core, Dataminr ensures its customers receive the most relevant and accurate intelligence with unmatched speed, scale, and accuracy—hours or even days ahead of conventional sources, integrating external and proprietary internal data.

Appendix 1



CVE-2025-55182			
CVSS: 10.0 At-risk industries: Many Overall Risk: Critical			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
React2Shell—an unauthorized remote code execution (RCE) vulnerability that allows an attacker with no authentication to run arbitrary code on the server process.	The underlying technique (T1190) allows for exploiting public facing applications. Patching the SW is most important but you should also ensure that your externally facing applications have limited access to internal or business critical data via segmentation and/or Zero Trust architectures.	Very High Considering there is no authentication required, the likelihood of an attacker succeeding is critical.	\$\$\$\$ The impact of the Apache Log4j CVE and the MOVEit CVE are similar to this CVE. Apache Log4j caused an estimated \$10B+ in remediation costs, while MoveIT cost between \$9B and \$12B. Per company impacts range from \$2-10M for mid-market firms and \$50M+ for large enterprises.

CVE-2024-1709			
CVSS: 9.8 At-risk industries: Government MSPs Overall Risk: Very High			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
Critical authentication bypass vulnerability in ConnectWise ScreenConnect, a widely used remote monitoring and management (RMM) / remote access tool. Allows an unauthenticated attacker to gain admin access to ScreenConnect.	Patch the CVE or disable RMM.	High No authentication required but ConnectWise users have to initiate the connection.	\$\$\$\$ Similar to SolarWinds Orion but with a lower blast radius. The impacts for an enterprise would range between \$3M (for remediation in a non-systemic impact) to \$75-100M systemic loss.

CVE-2025-53770			
CVSS: 9.8 At-risk industries: Many Overall Risk: Very High			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
oolShell—a remote code executing (RCE) in on-premises Microsoft SharePoint Server that allows an unauthenticated attacker to run arbitrary code on the SharePoint server over the network.	Beyond patching, users should enable Antimalware Scan Interface (AMSI) in sharepoint to ensure EDR platforms are set up to detect this type of attack.	Moderate This CVE exploits on premise SharePoint installations, which means an attacker would first have to bypass existing controls in order to exploit this CVE.	\$\$\$\$ The impact of the SharePoint CVE would involve remediation, DFIR, and operational impacts at a minimum. These could range from \$500K to \$10M (depending on the size of the company). If this CVE leads to a data breach or Ransomware Event, the impacts could easily exceed \$50M to \$100M+.

CVE-2025-32433			
CVSS: 10 At-risk industries: Telecommunications Overall Risk: High			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
A critical remote code execution (RCE) vulnerability in the SSH server implementation of the Erlang/OTP (Open Telecom Platform). Could grant attackers full access to a system.	Patch the CVE or use firewalls to restrict SSH access to trusted management hosts only.	Very High Internet facing machines can be exploited by attacks that do not require authentication.	\$\$\$ Impacts would include remediation (\$3-15M), containment (\$1-5M), and exposures via Ransomware or Databreach (\$15M-100M)

CVE-2025-5777			
CVSS: 9.4 At-risk industries: Financial Services Overall Risk: High			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
CitrixBleed 2— Out-of-bounds memory read vulnerability affecting Citrix NetScaler ADC (Application Delivery Controller) and Citrix NetScaler Gateway depending on configuration. Could allow attackers to steal memory contents from the appliance.	Patch the CVE, ensure DLP is in place and configured correctly, and monitor logs and network traffic to look for anomalous authentication and session activity.	Very High Internet facing machines can be exploited by attacks that do not require authentication.	\$\$\$ Stealing data is always dangerous but the attacker would have to see the right data at the right time to cause material impact. The most likely costs for this involve DFIR (\$250K-1.5M) and \$1-5M in remediation (patching, cleanup). If the attack leads to a data breach, the impact would be much higher.

CVE-2024-55591			
CVSS: 9.6 At-risk industries: Government Overall Risk: High			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
A critical authentication bypass vulnerability in Fortinet FortiOS and FortiProxy, the core operating system that runs on Fortinet firewalls, SSL-VPN gateways, and secure proxy appliances. It leads to unauthenticated remote exploitation (no code required).	Patch the CVE and ensure http/https admin interfaces are disabled, admin access is restricted to only trusted IP's, and remote management interfaces from public IP's is restricted.	Very High Internet facing machines can be exploited by attacks that do not require authentication.	\$\$\$ Impacts would include DFIR (\$250k-2M), \$2-15M for remediation), and if a ransomware attack were to occur, \$50M+ (though the impact to government agencies would be to the mission, not financial).

CVE-2025-31324 CVSS: 9.8 At-risk industries: Manufacturing Overall Risk: Moderate			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
A Remote Code Exploitation on SAP NetWeaver that allows for Remote Code Execution (RCE) attacks. Attackers scan place web shells or arbitrary binaries and then control the entire system, thus crippling a company.	Beyond patching, ensuring that network access to the vulnerable systems (firewall rules, etc) is key.	Low Typically behind a set of defenses (Firewall, DMZ) so attackers have to get through existing defenses to execute an attack.	\$\$ Customers use SAP for key parts of their business and as such, the impact would be high (comparable to a Nork Hydro—\$150M+ in losses, Maersk—\$250M+, or Merck—\$300M)

CVE-2024-4577 CVSS: 9.8 At-risk industries: Many Overall Risk: Moderate			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
Effectively a bypass of a long-standing PHP CGI fix originally implemented to stop CVE-2012-1823. Attackers gain the same privileges as the web server processes.	Patch the CVE or use WAF rules targeting known exploit patterns.	Moderate Primarily effects windows servers with php running in CGI mode. Some mitigations (such as WAF rules should already be in place).	\$\$ Mostly targeted hosted sites.

CVE-2023-6553 CVSS: 9.8 At-risk industries: Many Overall Risk: Low			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
Affects Backup Migration plugin for WordPress. It allows unauthenticated attackers to execute arbitrary PHP code on affected servers via a flaw in the plugin's file handling logic. Attackers can gain remote code execution (RCE).	Patch the CVE, disable the plugin, or restrict public access (if possible).	Very High No authentication required to create the exploitation.	\$ Most Wordpress usage is on marketing sites that don't have connectivity to production systems. The impact would be minor

CVE-2024-36401			
CVSS: 9.8 At-risk industries: Government Overall Risk: Low			
ABOUT		IMPACT	
DESCRIPTION	MITIGATION STEPS	LIKELIHOOD OF IMPACT	FINANCIAL RISK (\$-\$\$\$\$)
A remote code execution vulnerability in GeoServer, an open-source Java server used to publish, share, and edit geospatial data using Open Geospatial Consortium (OGC) standards—such as WFS, WMS and WPS. Exploitation could fully compromise the underlying systems.	Remove the vulnerable library module and/or patch.	High Typically behind a set of defenses (Firewall, DMZ), so attackers have to get through existing defenses to execute an attack.	\$ Agencies using Geoserver would expect to spend \$500K to \$5M per affected environment for remediation. This does not take into account the mission impact of losing access to geo data for key missions.



About Dataminr

Dataminr is the global leader in AI-powered real-time event, threat & risk intelligence. The company delivers the earliest actionable intelligence on breaking events, emerging threats, and unexpected risks across the physical, digital, and cyber domains. Dataminr first pioneered Multi-Modal Fusion AI, synthesizing text in 150 languages, image, video, audio, and sensor signals across 1M public data sources to deliver the fastest, most accurate real-time detection. Dataminr’s AI innovations, including ReGenAI, Intel Agents, and PreGenAI, build on this foundation by delivering Live Briefs, Agentic AI-powered context, and Predictive Intelligence. More than 100 U.S. government agencies, 20 international governments, two-thirds of the Fortune 50, and half of the Fortune 100 trust Dataminr to protect people, assets, and operations and respond with unmatched speed and confidence.



About ThreatConnect

ThreatConnect provides solutions to enable cyber defenders to continuously manage threat exposure and improve cyber resilience. Our threat and risk-informed defense products give defenders the advantage over adversaries with rich context, risk-based prioritization, and the ability to quickly and precisely act on emerging threats. Our products span threat, risk, and security operations, and come together in a single intelligence hub. More than 250 global enterprises rely on ThreatConnect every day to contextualize and prioritize emerging threats and automate defenses.